

DATA-260 Lab 1 – Report

Pair 06 · Uday Patel (Part A) and Sreeramachandra Sai Achutuni (Parts B and C)

Item	Value
Repository	https://github.com/UdayPate/data260-pair06 (private)
Tagged commit	<!-- FILL AT THE END: final commit hash, tag lab1 -->
Hardware	Lenovo Legion Slim 5 (16-inch, Ryzen 5 7640HS, 16 GB RAM, RTX 4060 8 GB), Windows, MySQL 8 local
Local model	qwen3:8b via Ollama (Parts B and C)

Section 1 – Goals

Lab 1 asks for a Handshake-style career platform with two personas, **Student** and **Company**, and a hand-built AI assistant that works on the platform’s own data. The platform uses React (front end), FastAPI (back end) and MySQL (database). The assistant uses a local Ollama model and an agent loop written by hand, with no agent framework. The lab is worth 40 points.

Part	What it asks for	Points	Owner
A	The platform: both personas, REST API, validation, authorization, Swagger or Postman documentation, seed generator	22	Uday
B	Agent loop, one model client class, five tools, five transcripts	12	Partner
C	Confirmation gate, prompt-injection defence, tool-call reliability table	6	Partner

This report covers all three parts. Sections 1 to 6 are Part A. Sections 7 to 10 are Parts B and C.

The goals for Part A, taken from the handout:

- **Student:** sign up (bcrypt) and sign in/out with a token; profile with every updatable field and a picture; search jobs by company or title and filter by category and city; job and company details; apply with a PDF resume and filter own applications by Pending, Reviewed or Declined; events in date order, search, register when eligible; browse students by name or college and filter by major; AI chat on the home page.
- **Company:** sign up and sign in/out; post jobs; see own postings and who applied; open a student profile, preview the PDF resume and set the status; company profile with picture; Students tab (name, college, skills); Events tab (post events, see registered students).
- **Back end and front end:** validate every input, encrypt passwords, handle exceptions, restrict users to authorized actions; React with Bootstrap, Axios, loading and error states, separate components, pages and services; Swagger UI or a Postman collection.
- **Data:** at least 300 jobs, 1,500 applications, 200 students, 50 companies and 100 events across CITY_SET, generated with `random_state = SEED` by a committed script.

How we know each goal is met: the requirement-to-code-to-test table is in `docs/PART_A_CHECKLIST.md`, the API evidence is in section 6, and the test counts are in section 6 and `METRICS.md`.

Section 2 – System design

2.1 – Architecture

```
Browser (React 18 + Vite + react-bootstrap, http://localhost:9061)
  | pages -> services/*.js -> services/api.js (Axios, adds the token, one place for errors)
  v HTTP + JSON, header Authorization: Bearer <JWT>
FastAPI (http://localhost:9060, Swagger UI at /docs)
  routers/ HTTP only: path, status code, which role may call it
  schemas/ Pydantic v2: validates every request body and shapes every response
  services/ business rules and queries (jobs, events, students, preferences, applications)
  models.py SQLAlchemy 2.0 tables
  | ^
  | +-- services/ is also what the AI assistant tools call (Parts B and C),
  v so the assistant gets the same permission rules as the website
MySQL 8 (database p06_handshake) uploads/ (resumes: private; profile_pics: public)
```

JWT = JSON Web Token. CORS (Cross-Origin Resource Sharing) allows only the React origin (port 9061).

2.2 – Layers and why they are split

Layer	Folder	Rule it follows
Router	backend/app/routers/	Thin. Reads the request, calls one service function, returns the result.
Schema	backend/app/schemas/	Every request body is a Pydantic model that checks types, lengths and ranges. The job, event, preference, profile-update, status-update and chat bodies also use <code>extra="forbid"</code> , so an unknown field such as <code>company_id</code> gets 422. The signup and login bodies do not forbid extra fields; unknown fields there are ignored and never reach the database.
Service	backend/app/services/	All business rules and SQL. The website and the assistant call the same functions.
Model	backend/app/models.py	Table definitions, enums, UNIQUE constraints.
Core	backend/app/core/	Password hashing, JWT, role checks (<code>deps.py</code>), safe uploads.

Front end: pages never call Axios directly. Pages call `services/*.js`, which call `services/api.js`. The `useAsync` hook gives every request a loading state, an error state and a reload. Array filters are sent as repeated keys (`paramsSerializer: { indexes: null }`), which is what FastAPI expects.

2.3 – Data model

Twelve tables (all in `backend/app/models.py`):

Table	Purpose	Notable constraints
students	Student account and profile	email unique, password_hash (bcrypt)
student_skills, student_experience	Skills and work history	skill unique per student; cascade delete
student_preferences	Saved job and event preferences (read by the assistant)	one row per student
companies	Company account and profile	email unique
jobs, job_skills	Postings and required skills	enums for category and pay period; skill unique per job
applications	A student applying to a job, with resume path and status	UNIQUE (student_id, job_id)
events, event_eligible_majors	Events and the majors allowed (one row All = open to everyone)	UNIQUE (event_id, major)
event_registrations	A student registered for an event	UNIQUE (student_id, event_id)
saved_items	Jobs or events saved by the assistant's save_job_or_event tool	UNIQUE (student_id, item_type, item_id)

In this report a **job posting** is a row in `jobs` (the API paths say `/jobs`). Relationships: a company has many job postings and events; a job has many applications; a student has many applications and registrations. Foreign keys use `ON DELETE CASCADE`. Application status is the enum Pending, Reviewed, Declined; job category is the enum `full_time`, `part_time`, `on_campus`, `internship`.

2.4 – Authentication

- Passwords are hashed with `bcrypt` (the library's default cost, 12 rounds; `core/security.py`). At least 8 characters, one letter and one digit, at most 72 bytes (the `bcrypt` limit). The hash is never returned by any endpoint.
- `POST /auth/login` returns a JWT (HS256, 8 hours) that holds the user id, the role and the expiry. The client sends it as `Authorization: Bearer <token>`. A wrong email and a wrong password give the same reply (`test_login_wrong_password_and_unknown_email_look_identical`).
- `core/deps.py` turns the token into the current user. A missing, forged or expired token gives **401**. `require_student` and `require_company` give **403** to the wrong role.
- The JWT secret and the database password come from `backend/.env`, which is git-ignored.

2.5 – Authorization and role rules

Rule	Behaviour	Test that checks it
Missing, garbage, expired, wrongly signed token, or deleted account	401	test_auth.py::test_missing_or_garbage_token_is_401, test_expired_token_is_401, test_token_signed_with_wrong_secret_is_401, test_token_for_deleted_account_is_401
A user's own data	Always taken from the token (/students/me), never from an id in the URL	By design (the routes have no id); no single test is named for it
Another person's resume	404 , not 403, for another student, for a company that does not own the job, and for an id that does not exist (same reply body); 401 when not logged in	test_applications.py::test_everyone_else_gets_404_for_a_resume
Another company's application	GET /applications/{id} gives 404 ; a student calling that company-only endpoint gets 403	test_applications.py::test_applicant_detail_privacy
Applicants list of a job posting the company does not own	403 (the posting itself is public, so its existence is not secret); a student gets 403; a missing posting is 404	test_applications.py::test_applicants_list_is_private_to_the_job_owner
Company editing a job posting or event it does not own	403	test_jobs.py::test_cannot_edit_someone_elses_job_or_a_missing_job, test_events.py::test_cannot_edit_someone_elses_event_or_a_missing_one
Event registration when the student's major is not eligible (or the student has no major and the event is not open to all)	403 with the reason in the message	test_events.py::test_ineligible_student_is_refused_with_a_clear_reason, test_student_without_a_major_can_only_join_open_events
Registering for a past event	409	test_events.py::test_cannot_register_for_past_or_missing_events_or_as_other_roles
Duplicate application, duplicate registration, signup with an existing email	409 (the UNIQUE constraint is the final guard against two clicks at once)	test_applications.py::test_cannot_apply_twice_but_can_apply_to_other_jobs, test_events.py::test_cannot_register_twice_but_others_can, test_auth.py::test_duplicate_email_is_rejected_case_insensitively

Rule	Behaviour	Test that checks it
Resumes	Private. Served only by GET / applications/{id}/resume to the applicant and the owning company, with Cache-Control: private, no-store; the resumes folder is not mounted as static files	test_resume_files_are_not_served_as_static_files, test_profiles.py::test_resumes_folder_is_not_publicly_served
Profile pictures	Public under /media/profile_pics/	test_profiles.py::test_upload_picture_and_serve_it
What a company sees of a student in the list (GET / students)	Name, college, major, degree, graduation year, skills, city, state, email and GPA ; no phone, no date of birth	test_directory.py::test_company_list_shows_contact_and_academic_fields_but_never_dob_phone_or_password
What a company sees of one student (GET /students/{id}, applicant detail)	The list fields plus country, career objective, experience and phone ; never the date of birth	test_directory.py::test_company_opens_a_full_student_profile_without_dob_or_password, test_applications.py::test_applicant_detail_has_full_profile_without_date_of_birth
What a student sees of a peer	Name, college, major, degree, graduation year, skills, picture, career objective, experience; no email, phone, GPA, date of birth, city or state	test_directory.py::test_peers_never_get_email_phone_gpa_dob_or_city

Uploads are checked by content: resumes must start with %PDF- (5 MB limit); pictures must be PNG, JPEG or WebP by magic bytes (2 MB limit). File names are generated by the server.

2.6 – Where the assistant plugs in

POST /assistant/chat (students only) takes {message, conversation_id} and returns {reply, conversation_id, tool_calls: [{name, arguments, result}]}. The router, schemas, tests and the React chat window exist. Parts B and C replace only the body of run_assistant() in backend/app/services/assistant.py. The student comes from the token, so the assistant can only act for the person who is logged in.

Section 3 – Pair parameters

Parameter	Rule from the handout	Value
PAIR	Assigned on Canvas	06
PORT_BASE	9000 + (PAIR × 10)	9060
Back end (FastAPI)	PORT_BASE	9060
Front end (React dev server)	PORT_BASE + 1	9061

Parameter	Rule from the handout	Value
Database and Kafka prefix	p{PAIR}	p06 (database p06_handshake)
SEED	PAIR, for every generator and random_state	6 (random.Random(6), Faker.seed_instance(6))
CITY_SET	Assigned on Canvas	San Jose, Sunnyvale, Mountain View

Source: `backend/app/config.py` (the same values are in `README.md`). Seeded demo logins: `demo.student@sjsu.edu` and `demo.company@example.com`; the password is not repeated here.

Section 4 – Seed counts

The generator is `backend/seed/generate_seed.py`. It is run with `python -m seed.generate_seed --reset`, which drops and rebuilds `p06_handshake`. Every random choice uses `random.Random(6)` or a `Faker` seeded with 6, so running it again gives identical data. Cities for jobs, events, students and companies are chosen from `CITY_SET`.

Counts below are the real MySQL row counts measured by `python -m scripts.collect_metrics` on 2026-10-08 23:17 (`docs/part_a_metrics.md`, `METRICS.md`):

Table	Rows	Required by the handout	Met
Companies	50	50	yes
Students	200	200	yes
Job postings	300	300	yes
Applications	1500	1500	yes
Events	100	100	yes
Event registrations	400	n/a	n/a
Saved preferences	151	n/a	n/a
Saved items	150	n/a	n/a
Student skills	877	n/a	n/a
Job skills	1073	n/a	n/a

Rows beyond the handout’s minimums exist so every feature has something to show. The first six jobs are fixed “scenario” jobs (three remote Data Science jobs and one Data Analyst job in each of the three cities) with deadlines in 2027, so the Part B test queries always find them. Evidence of the run: `RUN_LOG.txt` (seed output) and the row-count screenshot in section 5.

Section 5 – Screenshots

Screenshots are in `docs/screenshots/`. Figures marked **SCREENSHOT PENDING** have not been captured yet.

5.1 – App screens (React)

SCREENSHOT PENDING

ui_01_student_home_chat.png

Figure 1: Student home page with the AI assistant chat window

SCREENSHOT PENDING

ui_02_job_search_filters.png

Figure 2: Job search with filters

SCREENSHOT PENDING

ui_03_my_applications_resume.png

Figure 3: My applications with the resume window

SCREENSHOT PENDING

ui_04_company_applicant_detail.png

Figure 4: Company view of one applicant, with resume preview and status buttons

5.2 – Swagger UI: sign-in, profile and jobs (student token)

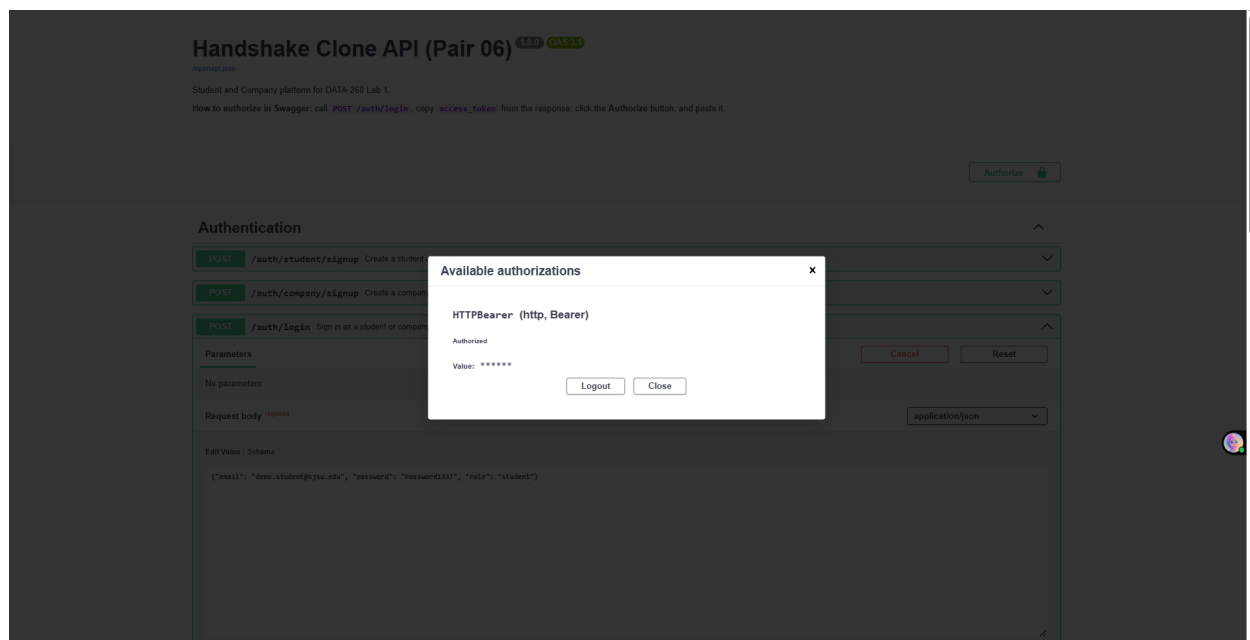


Figure 5: Swagger Authorize dialog with the login request body (token hidden)

Responses	
Curl	
<pre>curl -X 'GET' \ 'http://localhost:9060/students/me/preferences' \ -H 'accept: */*' \ -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpVC3Q9 eyJzdWI0IjIiIiwicm9zZSI6IiN0dW1hbnQlIiwiaWF0IjE5OTE8ODc0E00gImV4cCI6MTc5MTUxNDQ0Q000.BLkrrHhWmX2bs0FPIm-KoKlipQo5ltgP515G--o760'</pre>	
Request URL	
http://localhost:9060/students/me/preferences	
Server response	
Code	Details
200	
Response body	
<pre>{ "saved": true, "preferred_categories": ["internship"], "preferred_cities": ["San Jose"], "preferred_roles": ["Data Analyst", "Data Science"], "min_hourly_rate": 25, "open_to_remote": true, "event_interests": ["Career Fair", "Tech Talk"], "updated_at": "2026-10-07T13:12:14" }</pre>	
Response headers	
<pre>content-length: 258 content-type: application/json date: Thu, 08 Oct 2026 17:46:58 GMT server: uvicorn</pre>	
Responses	
Code	Description
Links	

Figure 10: GET /students/me/preferences

5.3 – Swagger UI: applications and events (student token)

<pre> -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1bm90YS1hcGFudXkiOiJ0MTU0MDY1MjY0Lm90YS1hcGFudXkiLCJ0eXAiOiJKV1QiLCJ0aWQiOiJ0MTU0MDY1MjY0Lm90YS1hcGFudXkiLCJ1b250PS15MDYyZW50eXkiOiJ0MTU0MDY1MjY0Lm90YS1hcGFudXki' -H 'Content-Type: form-data' \ -f resume@FA55-11_hah.pdf?type=application/pdf' </pre>		
Request URL	http://localhost:9060/jobs/123/apply	
Server response		
Code	Details	
201	Response body	<pre> { "id": 123, "status": "Pending", "applied_at": "2020-10-07T14:05:19", "resume_url": "/applications/123/resume", "job": { "id": 123, "title": "Sales Development Representative Intern", "company_id": 9, "company_name": "Hugoboss", "city": "Geneva", "is_remote": true, "category": "internship", "deadline": "2020-12-31", "is_expired": false } } </pre>
	Response headers	<pre> access-control-allow-credentials: true content-length: 322 content-type: application/json date: Wed, 07 Oct 2020 21:05:18 GMT server: nginx </pre>
Responses		
Code	Description	Links
201	Successful Response	No links
	Media type	
	application/json	
	Controls Accepted Header	
	Example Value	Schema
	<pre> { "id": 1, "status": "Pending", "applied_at": "2020-10-07T21:05:19.334Z", "resume_url": "string", "job": { "id": 1, "title": "string", "company_id": 1, "company_name": "string", "city": "string", "is_remote": true, "category": "full_time", "deadline": "2020-10-01", "is_expired": true } } </pre>	No links
422	Validation Error	
	Media type	
	application/json	

Figure 11: POST `/jobs/123/apply` with a PDF resume returns 201

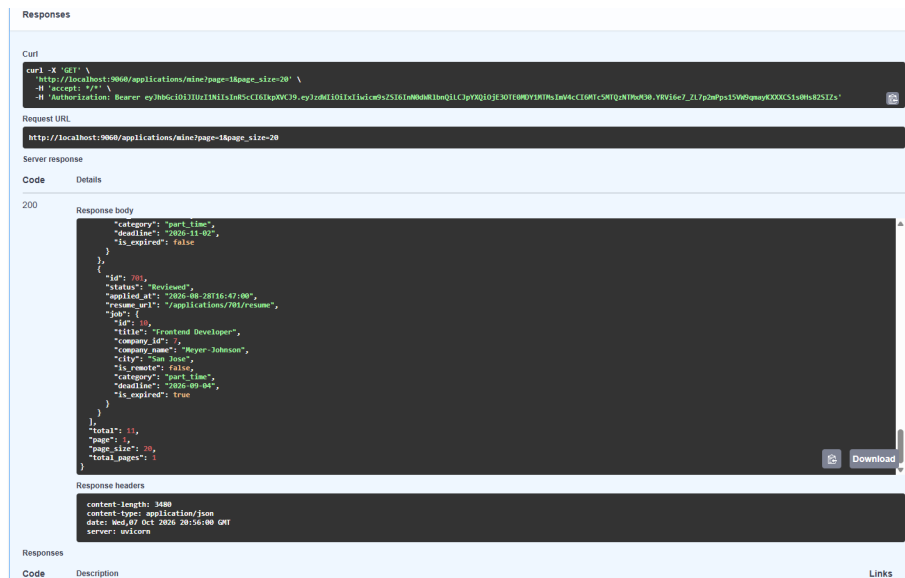


Figure 12: GET /applications/mine

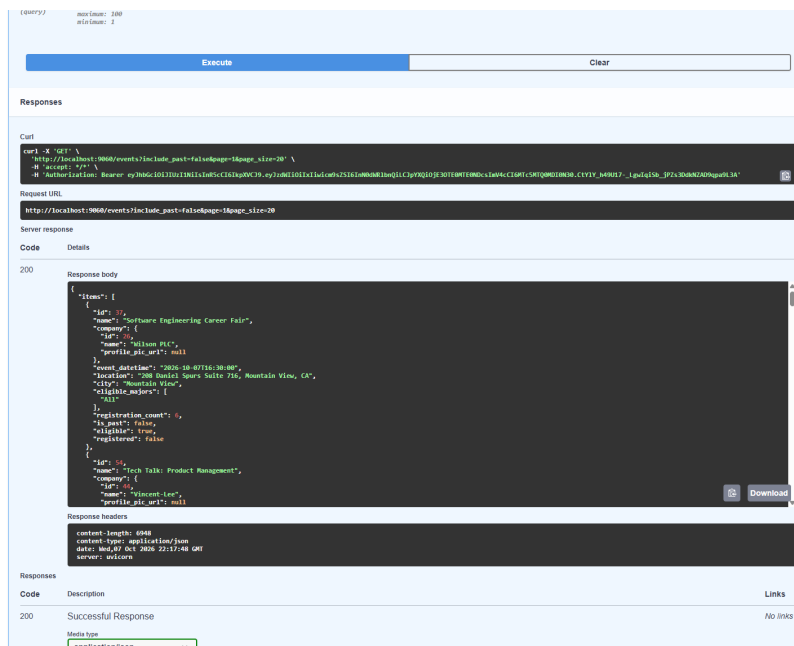


Figure 13: GET /events (upcoming)

3

documented

Details

Error: Forbidden

Response body

```
{
  "detail": "This event is open to Computer Science, Marketing majors only (your major: Data Science)"
}
```

Response headers

```
access-control-allow-credentials: true
content-length: 104
content-type: application/json
date: Wed, 07 Oct 2026 22:21:44 GMT
server: uvicorn
```

sponses

id

Description

Links

Figure 17: Registering for an event closed to the student's major returns 403

5.4 – Swagger UI: student directory, student token and company token

[illegible]

Figure 18: GET /students as a student (peer view, no email)

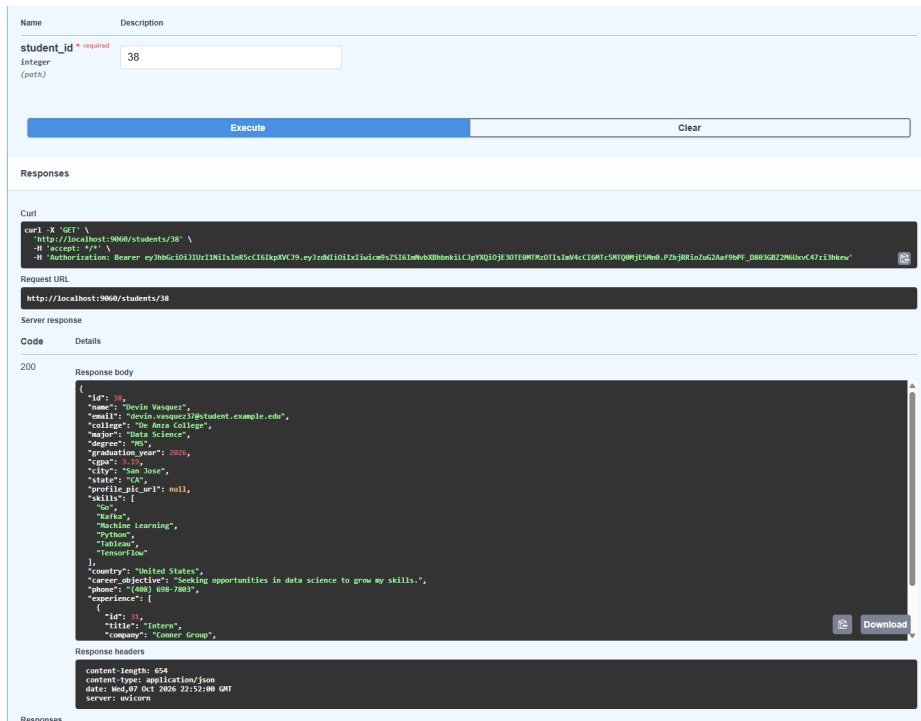


Figure 21: GET /students/38 as a company (email, GPA and phone)

5.5 – Swagger UI: company token

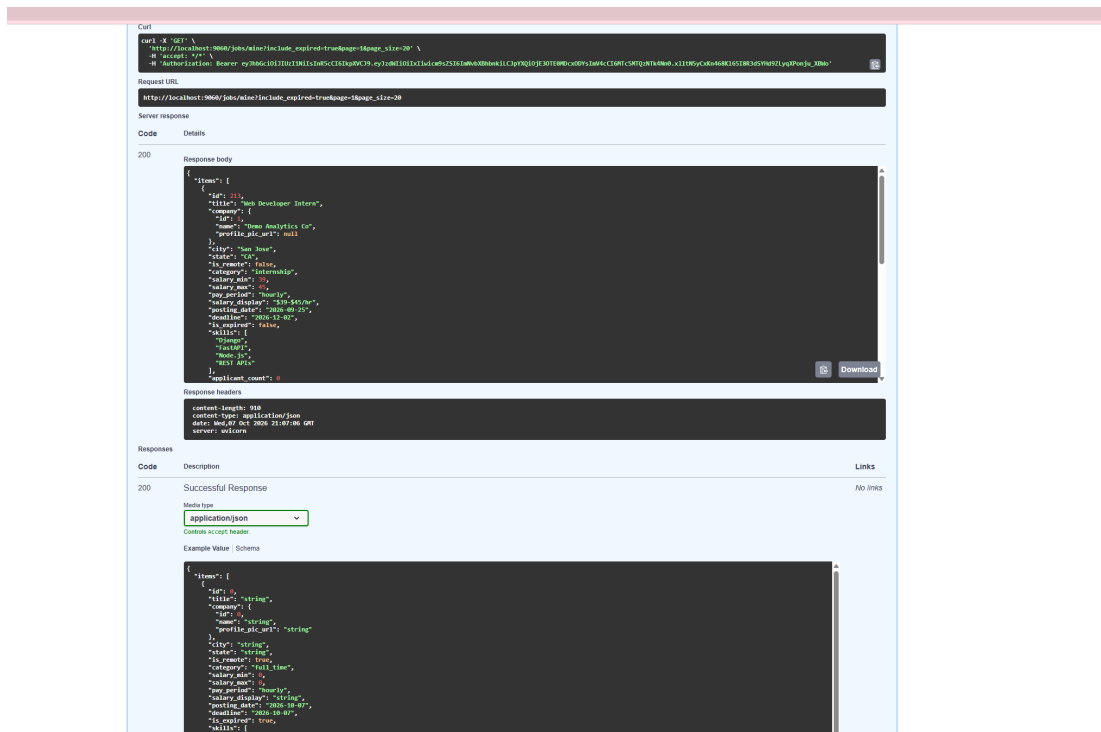


Figure 22: GET /jobs/mine

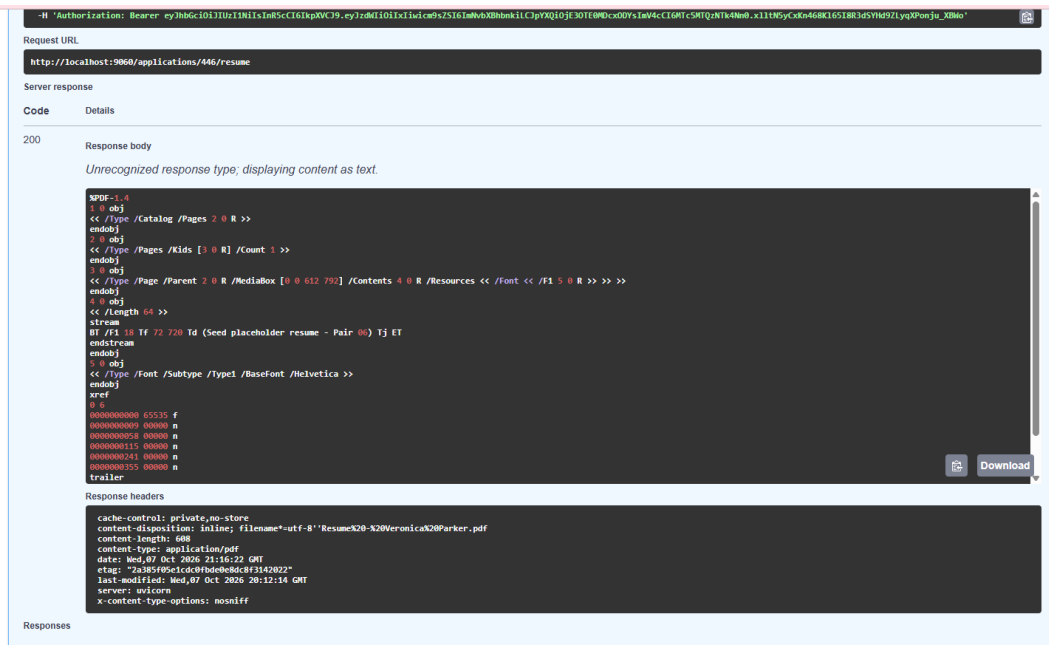


Figure 25: GET /applications/446/resume returns the PDF with private headers

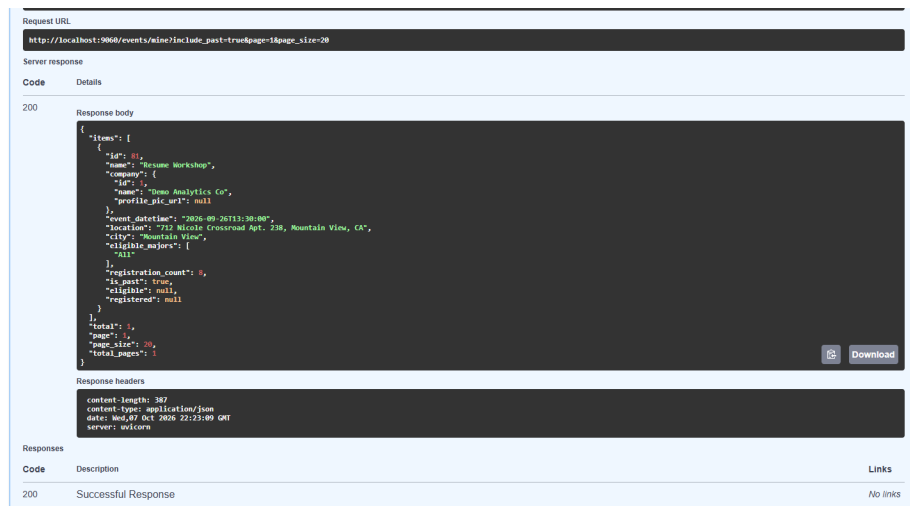


Figure 26: GET /events/mine

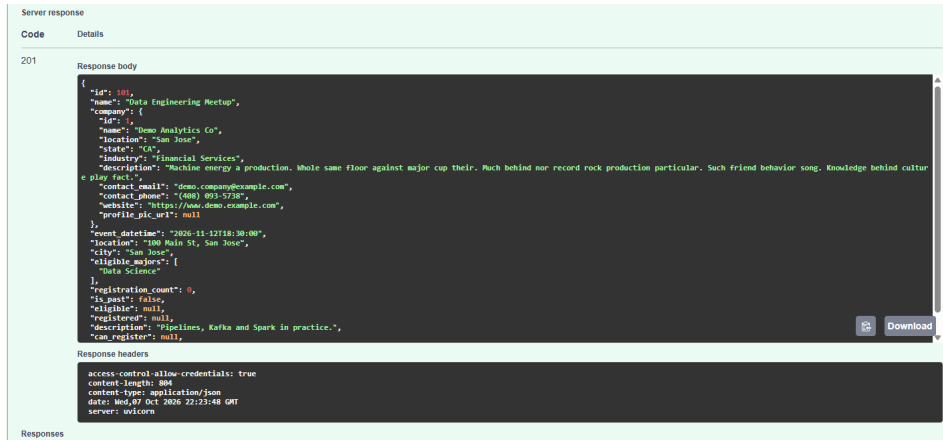


Figure 27: POST /events returns 201

5.6 – Tests, row counts and git history

SCREENSHOT PENDING

test_01_pytest_summary.png

Figure 28: pytest summary (346 passed)

SCREENSHOT PENDING

test_02_npm_summary.png

Figure 29: npm test summary (148 passed)

SCREENSHOT PENDING

db_01_row_counts.png

Figure 30: MySQL row counts for p06_handshake

SCREENSHOT PENDING

git_01_history.png

Figure 31: Git commit history showing both partners (taken last)

A note on dates: the Swagger screenshots were taken on 6 to 7 October 2026 against a live database. Two of them (api_04, application id 1501, and api_20, event id 101) created extra rows, so the live database held 1,501 applications and 101 events at that time. The row counts in section 4 were measured later, after `python -m seed.generate_seed --reset` (RUN_LOG start 2026-10-08 22:54), and show 1,500 and 100.

Section 6 – API tests

6.1 – Swagger evidence

Swagger UI (<http://localhost:9060/docs>) was used with the demo student and demo company logins. Each line says what the screenshot in section 5 proves. The Swagger set has no screenshot of a 401 or a 404; those two codes are covered by the pytest output in 6.2.

Screenshot	What it proves
api_01_authorize_dialog.png	Bearer-token authentication is wired into Swagger: POST /auth/login takes {email, password, role} and the token goes into Authorize (value masked).
api_02_jobs_filters_200.png	200. Search and filters work together: q=data science, category=internship, is_remote=true, skills=Python&skills=Machine Learning (repeated keys), skills_match=any, include_expired=false; total is 3 with paging fields.
api_03_student_preferences_200.png	200. A student reads their own saved preferences (categories, cities, roles, minimum hourly rate, remote, event interests). This is the data the assistant's get_student_preferences tool reads.
api_04_student_apply_201.png	201. Multipart PDF upload creates an application with status Pending; the resume is exposed only as the protected path /applications/1501/resume.
api_05_student_my_applications_200.png	200. A student lists only their own applications (total 11) with date, status (here Reviewed) and job summary.
api_06_student_events_200.png	200. Upcoming events (include_past=false) with registration_count, eligible and registered flags for the logged-in student.
api_07_student_events_filtered_200.png	200. Event filters by date_from, date_to and major; 18 results. The last one shows registered: true.
api_08_event_register_201.png	201. Eligible student registers for event 59 (open to All).
api_09_event_register_409_duplicate.png	409 Conflict, You are already registered for this event (duplicate registration rule).
api_10_event_register_403_major.png	403 Forbidden, eligibility rule: the event is open to Computer Science and Marketing only and the student's major is Data Science.
api_11_student_directory_peer_no_email.png	200. GET /students?major=Data Science as a student: peer cards contain name, college, major, degree, graduation year, picture and skills, and no email, phone or GPA (total 25).
api_12_student_profile_peer_no_email.png	200. A student opening a peer profile gets the limited view plus career objective and experience; still no email, phone, GPA or date of birth.
api_13_company_students_with_email.png	200. The same directory called with a company token includes email and cgpa.

Screenshot	What it proves
api_14_company_student_detail_with_email_phone.png	200. A company opening one student sees email, GPA and phone. The date of birth is not in the visible part of the body; its absence is checked by pytest (see 6.2).
api_15_company_jobs_mine_200.png	200. A company lists only its own job postings, with <code>applicant_count</code> (expired ones included because <code>include_expired=true</code>).
api_16_company_application_detail_200.png	200. Company opens applicant 446: status, resume URL and the student's profile with contact details.
api_17_company_status_reviewed_200.png	200. PATCH <code>/applications/446/status</code> changes Pending to Reviewed.
api_18_company_resume_pdf_200_private.png	200. The resume is served only through the authenticated route: <code>content-type: application/pdf</code> , <code>cache-control: private</code> , <code>no-store</code> , <code>content-disposition: inline</code> , <code>x-content-type-options: nosniff</code> . The file is the seed's placeholder PDF.
api_19_company_events_mine_200.png	200. A company lists only its own events (here one past event with 8 registrations).
api_20_company_post_event_201.png	201. Company posts an event (id 101) restricted to Data Science; the response echoes the company and eligible majors.

6.2 – Automated tests (pytest)

Command: `python -m pytest -v` in `backend/`, on an in-memory SQLite database (never MySQL). The full verbose output is saved in `docs/part_a_tests.txt`. It was run on 2026-10-09 with Python 3.13.2 and pytest 8.3.3 and ends with:

```
346 passed, 1 warning in 182.34s (0:03:02)
```

The earlier run recorded in `RUN_LOG.txt` also passed 346 tests (216.73 s). Tests per file in `docs/part_a_tests.txt`:

File	Tests passed	Covers
<code>test_applications.py</code>	47	Apply, resume rules, applicants, status, private resume route
<code>test_assistant.py</code>	12	The POST <code>/assistant/chat</code> contract (placeholder reply, validation, student-only)
<code>test_auth.py</code>	22	Signup, login, JWT checks, password rules
<code>test_directory.py</code>	26	Student directory and the two role views
<code>test_events.py</code>	72	Events, eligibility, registration, ownership
<code>test_jobs.py</code>	68	Job postings, search and filters, ownership
<code>test_preferences.py</code>	33	Saved preferences
<code>test_profiles.py</code>	66	Profiles, pictures, email changes, public and private files
Total	346	

The role-rule tests behind section 2.5 (each one passed in this run; the test names are in the table in 2.5):

Rule	Status code	Test file and function
No token, garbage token, expired token, wrong secret, deleted account	401	<code>test_auth.py::test_missing_or_garbage_token_is_401</code> , <code>test_expired_token_is_401</code> , <code>test_token_signed_with_wrong_secret_is_401</code> , <code>test_token_for_deleted_account_is_401</code>
Student calling a company-only endpoint, or the reverse	403	<code>test_applications.py::test_applicant_detail_privacy</code> , <code>test_jobs.py::test_cannot_edit_someone_elses_job_or_a_missing_job</code>
Another company's job posting or applicants	403	<code>test_applications.py::test_applicants_list_is_private_to_the_job_owner</code>
Another person's resume or application	404	<code>test_applications.py::test_everyone_else_gets_404_for_a_resume</code> , <code>test_applicant_detail_privacy</code>
Ineligible event registration	403	<code>test_events.py::test_ineligible_student_is_refused_with_a_clear_reason</code>
Duplicate application, registration or email	409	<code>test_cannot_apply_twice_but_can_apply_to_other_jobs</code> , <code>test_cannot_register_twice_but_others_can</code> , <code>test_duplicate_email_is_rejected_case_insensitively</code>
Bad input is refused	422	<code>test_applications.py::test_invalid_status_rejected[extra-field]</code> (unknown field), <code>test_jobs.py::test_invalid_edits_rejected_and_change_nothing</code> , <code>test_events.py::test_invalid_event_rejected[...]</code>
Resume must really be a PDF, at most 5 MB	4xx	<code>test_non_pdf_uploads_rejected[...]</code> (6 cases), <code>test_resume_over_5mb_rejected</code>
Company sees email and GPA but not phone or date of birth in the list; peers see neither	200	<code>test_directory.py::test_company_list_shows_contact_and_academic_fields_but_never_dob_phone_or_password</code> , <code>test_peers_never_get_email_phone_gpa_dob_or_city</code>

6.3 – Front-end tests and API documentation

`npm test` (Vitest, Testing Library, axios-mock-adapter) reported 14 test files and 148 tests passed in the run recorded in `METRICS.md` (16.69 s). It was not re-run for this report. API documentation exports are `docs/openapi.json` and `docs/postman_collection.json`.

Section 7 – Five transcripts

[To be added by Parts B and C from real runs.]

Section 8 – Reliability table

[To be added by Parts B and C from real runs.]

Section 9 – Injection before and after

[To be added by Parts B and C from real runs.]

Section 10 – Assistant tool-call evidence

[To be added by Parts B and C from real runs.]